

Authentication, Session & Access Control Flaws

1. INSECURE DIRECT OBJECT REFERENCE (PORTSWIGGER)

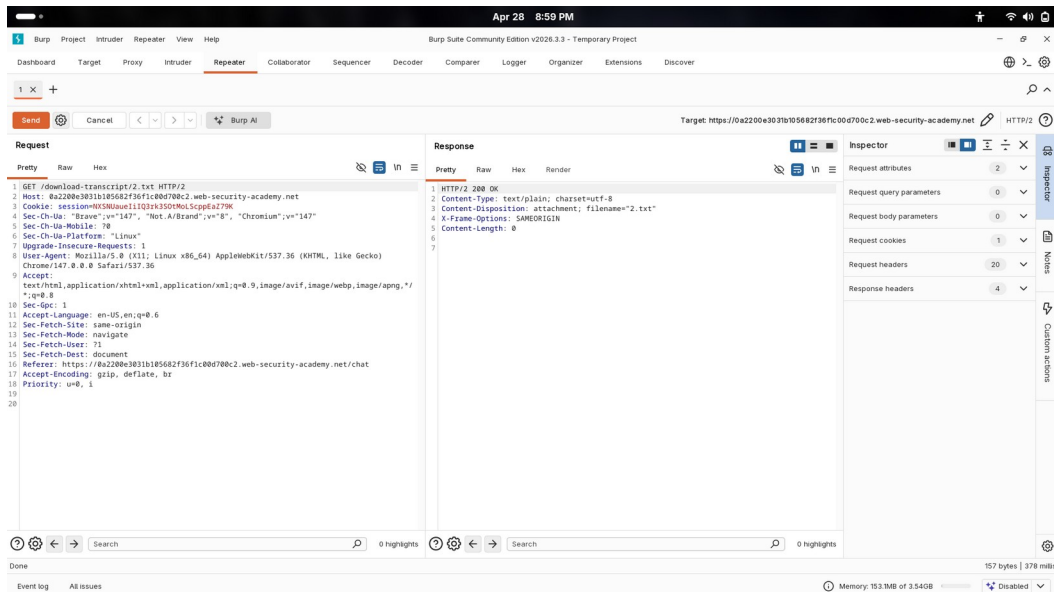
Vulnerability: Insecure Direct Object Reference (IDOR) - Private Chat Transcripts

Severity: High (7.5)

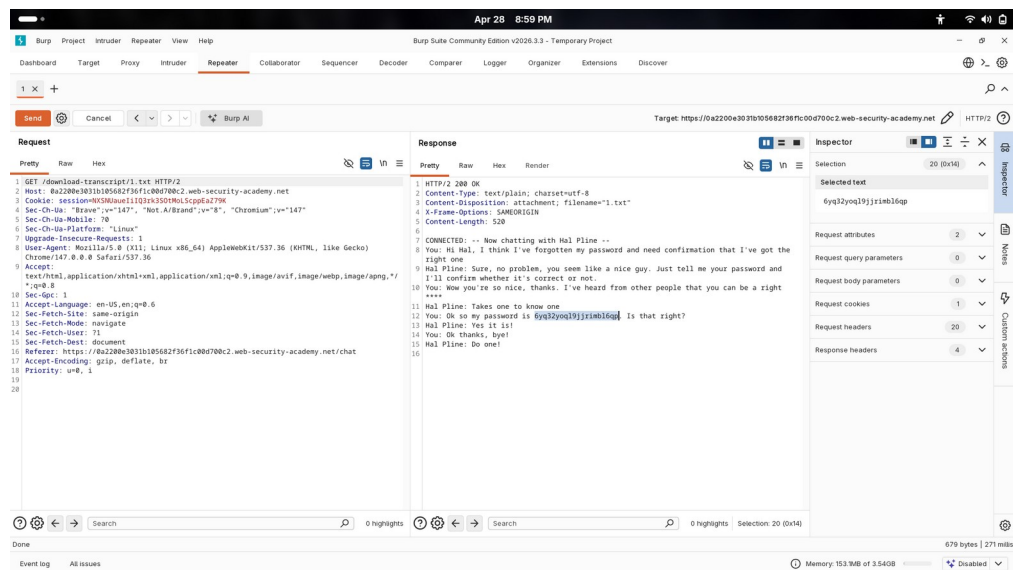
Description: The application stores chat transcripts as text files using a readable numeric names. It fails to validate if the requesting user has the authorization to view a specific transcript ID.

Payload: Change the GET request (in burpsuite)

from: /download-transcript/2.txt



to: /download-transcript/1.txt



Input: URL / Filename Parameter (1.txt)

Obtained Information: Sensitive user information, including a Password : 6yq32yoql9jjrimbl6qp

Remediation: Access control check, Indirect reference map, encoding the URL (replacing random URL instead of readable)

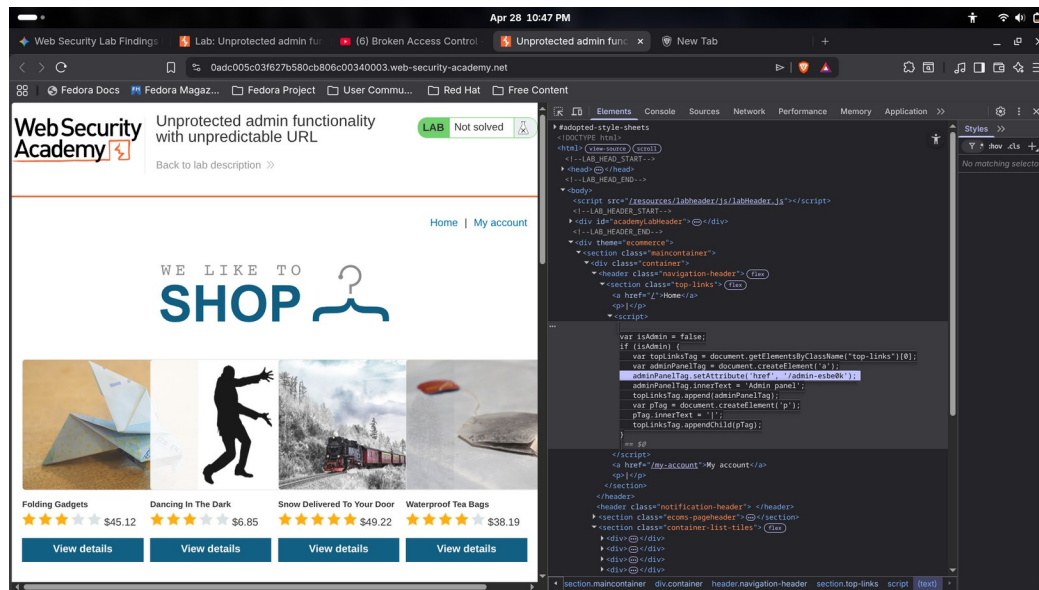
2. PRIVILEGE ESCALATION - VERTICAL (PORTSWIGGER)

Vulnerability: Unprotected admin functionality with unpredictable URL

Severity: High (7.5)

Description: The application is vulnerable and the admin access URL.

Payload: /admin-esbe0k

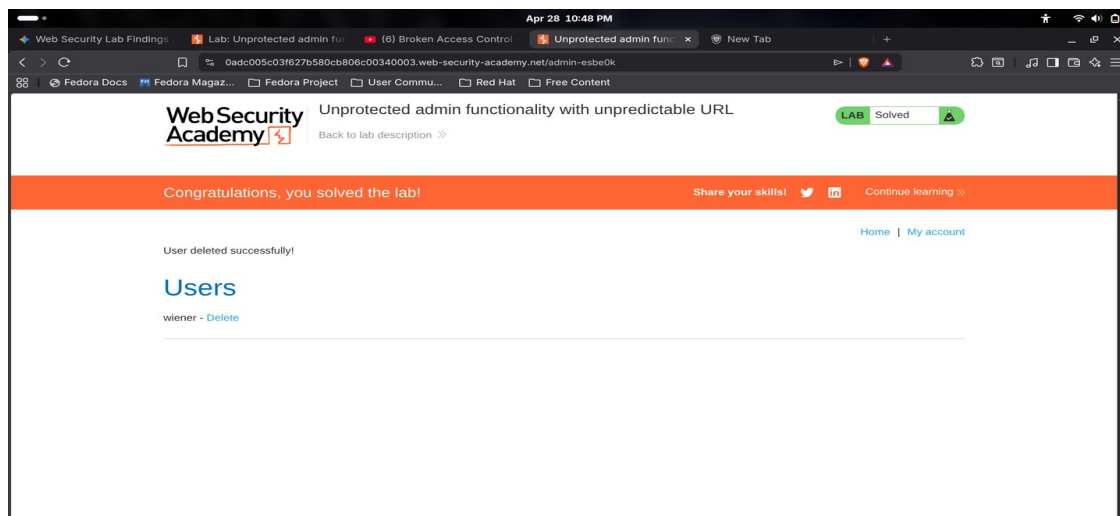


Input: URL – path

Obtained Information: Full access to the Admin panel

Impact: Complete System Compromise

Remediation: Strict authorization check on server side, deny by default



3. PRIVILEGE ESCALATION – HORIZONTAL (PORTSWIGGER)

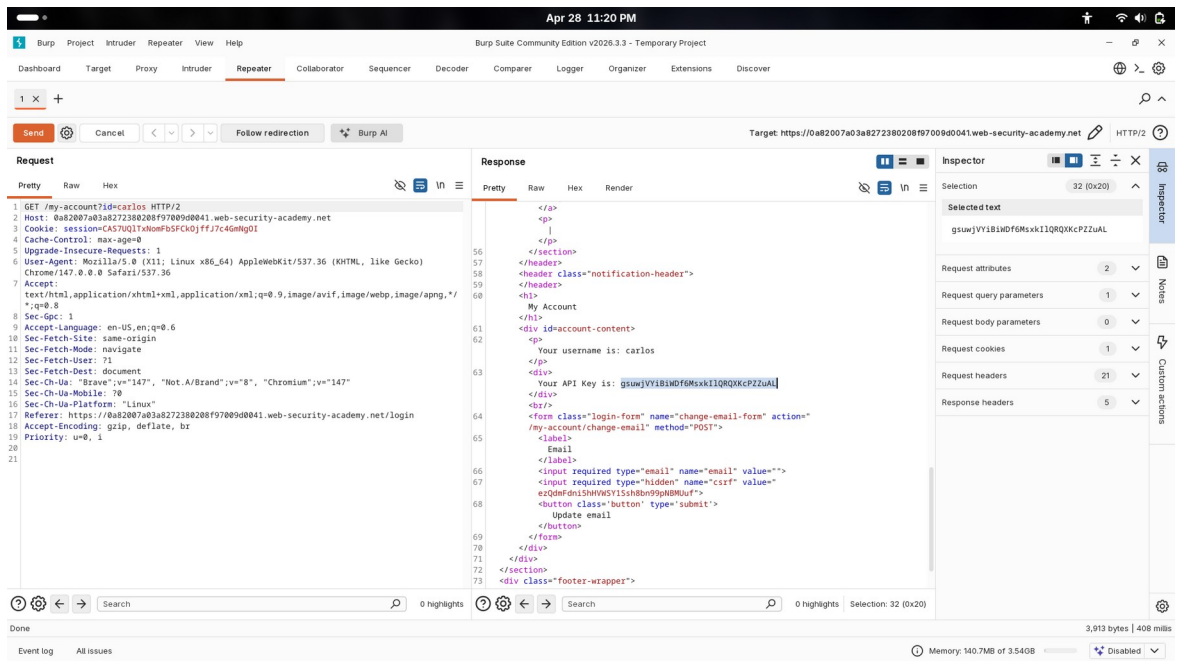
Vulnerability: User ID controlled by request parameter with data leakage in redirect

Severity: High (7.5)

Description: The application uses a `id` parameter to fetch user account pages.

Payload: GET /my-account?id=carlos

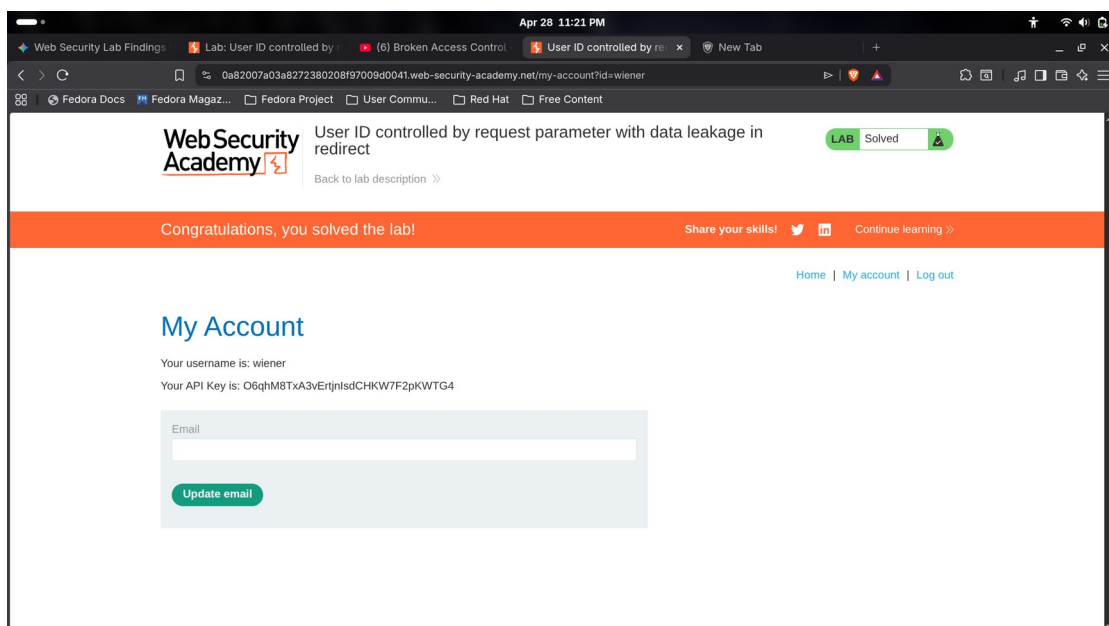
Input: URL Query Parameter (id) in burpsuite



Obtained Information: Account page of “carlos”, including API key

Impact: Information Disclosure, easy to bypass the frontend by using proxy

Remediation: Server-side authentication, session based identifications



4. AUTHENTICATION (PORTSWIGGER)

Vulnerability: Username enumeration via different responses

Severity: Medium (5.3)

Description: Application authentication responds with different error messages or response lengths depending on whether the username exists in the database.

Payload: Intruder (Sniper)

Input: Login Form

Obtained Information: username: alabama, password: monitor

Impact: Account takeover by using brute force

Remediation: Uniform error message, session based, setting up time limit for each failure login attempts.

This screenshot shows the results of an Intruder attack in Burp Suite. The 'Results' tab is active, displaying a table of requests and responses. The first request, with payload 'alabama', has a status code of 200 and a response length of 426. The 'Request' tab shows the raw HTTP data, including headers like 'Host: 0a09006e04ae1667873e5d2700d30022.web-security-academy.net' and a POST body with 'username=alabama' and 'password=monitor'.

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
1	alabama	200	426		3000	426	
2	carlos	200	403		3000	403	
3	root	200	275		3000	275	
4	admin	200	479		3000	479	
5	test	200	393		3000	393	
6	guest	200	393		3000	393	
7	info	200	335		3000	335	
8	adm	200	371		3000	371	
9	root	200	289		3000	289	
10	administrator	200	304		3000	304	
11	info	200	393		3000	393	
12	test	200	443		3000	443	
13	alabama	200	393		3000	393	

This screenshot shows the results of an Intruder attack in Burp Suite. The 'Results' tab is active, displaying a table of requests and responses. The first request, with payload 'root', has a status code of 200 and a response length of 275. The 'Request' tab shows the raw HTTP data, including headers like 'Host: 0a09006e04ae1667873e5d2700d30022.web-security-academy.net' and a POST body with 'username=root' and 'password=monitor'.

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
1	root	200	275		3000	275	
2	carlos	200	403		3000	403	
3	root	200	207		3000	207	
4	test	200	266		3000	266	
5	info	200	422		3000	422	
6	adm	200	354		3000	354	
7	root	200	337		3000	337	
8	root	200	444		3000	444	
9	administrator	200	479		3000	479	
10	info	200	376		3000	376	
11	test	200	379		3000	379	
12	test	200	207		3000	207	
13	root	200	392		3000	392	

This screenshot shows the 'My Account' page of the Web Security Academy. The page title is 'Username enumeration via different responses'. It displays the user's username as 'alabama' and email as 'alabama@normal-user.net'. There is a form to update the email address with an 'Update email' button. The page also includes a 'LAB Solved' badge and a 'Share your skillset' link.

Web Security Academy

Username enumeration via different responses

LAB Solved

Congratulations, you solved the lab!

Share your skillset

Home | My account | Log out

My Account

Your username is: alabama

Your email is: alabama@normal-user.net

Email

Update email